Informe del análisis y valuación de activos de información

AA1_EV01 – Actividad de aprendizaje 1: realizar la valuación de los activos de la organización

Erick Manuel Sang Cifuentes

Servicio Nacional de Aprendizaje SENA

Centro de Comercio y Turismo – Regional Quindío

Apropiación de los conceptos en ciberseguridad (programa 23310008, ficha 3640188)

Instructora: Luz Dary Bautista Parra

18 de octubre de 2026

Informe del análisis y valuación de activos de información

Introducción

La gestión de la seguridad de la información empieza por saber qué se debe proteger. Un activo de información es todo recurso que tiene valor para la organización y que interviene en el tratamiento de la información: datos, aplicaciones, equipos, redes, instalaciones y personas (International Organization for Standardization [ISO], 2022a). Sin un inventario de activos y una valoración de cada uno frente a la confidencialidad, la integridad y la disponibilidad, no es posible priorizar amenazas, estimar riesgos ni justificar controles.

Este informe tiene dos partes. En la primera se identifican, clasifican y valoran los activos de una organización de ejemplo, la Clínica Veterinaria Huellitas S.A.S., una pyme ficticia de Armenia (Quindío) que atiende consultas, cirugías, vacunación y venta de productos para mascotas. En la segunda se desarrolla el caso de estudio del componente formativo (el proyecto ASEGURA de una unidad de tramitación de expedientes) y se define el marco de referencia que mejor se ajusta a él.

Parte 1. Activos de información de la organización

Contexto y objetivos empresariales

Huellitas tiene una sede con dos consultorios, un quirófano, laboratorio básico y tienda de alimentos y accesorios, y trabaja con doce empleados. Sus objetivos son: (a) atender consultas y procedimientos con base en una historia clínica confiable de cada paciente; (b) agendar citas por teléfono, WhatsApp y su página web; (c) facturar electrónicamente y cobrar en efectivo, con tarjeta y por transferencia, y (d) fidelizar a los propietarios con recordatorios de vacunas y controles. Para cumplirlos depende de un conjunto de activos tecnológicos y de información, tangibles e intangibles, que se presentan a continuación.

¿Cuáles son los activos tangibles e intangibles?

Siguiendo las categorías propuestas en el componente formativo y en MAGERIT (Consejo Superior de Administración Electrónica, 2012), los activos se agrupan en

información, servicios, aplicaciones, equipamiento, comunicaciones, instalaciones, personal e intangibles. La Tabla 1 resume el inventario.

Tabla 1

Inventario de activos de información de la Clínica Veterinaria Huellitas

Categoría	Activo	Tipo	Propietario / responsable
Información (activo esencial)	Historias clínicas de los pacientes (diagnósticos, tratamientos, resultados de laboratorio e imágenes)	Intangible	Director médico
	Base de datos de propietarios: nombre, cédula, teléfono, dirección, correo	Intangible	Administradora
	Facturación, cartera y registros contables	Intangible	Contadora
	Inventario de medicamentos, incluidos los de control especial	Intangible	Regente de farmacia
	Información del personal (contratos, nómina, seguridad social)	Intangible	Administradora
Servicios	Agendamiento de citas (web, WhatsApp, teléfono)	Intangible	Recepción
	Facturación electrónica ante la DIAN (proveedor tecnológico)	Intangible (servicio de terceros)	Contadora
	Recaudo con datáfono y pasarela de pagos	Intangible (servicio de terceros)	Administradora
Aplicaciones	Software de gestión veterinaria (historia clínica, agenda, inventario) en la nube	Intangible	Administradora
	Página web con formulario de citas	Intangible	Proveedor externo
	Correo corporativo, WhatsApp Business y redes sociales	Intangible	Administradora
	Software contable	Intangible	Contadora
Equipamiento	Computadores de recepción, consultorios y administración (5)	Tangible	Administradora
	Equipo de rayos X digital y analizador de laboratorio conectados a la red	Tangible	Director médico
	Celular corporativo de WhatsApp; datáfono; impresora multifuncional	Tangible	Recepción
	Disco externo de copias de seguridad	Tangible	Administradora
Comunicaciones	Conexión a internet de fibra, router con wifi para empleados y wifi de invitados	Tangible / servicio	Administradora
Instalaciones	Sede de la clínica (recepción, consultorios, quirófano, rack de red)	Tangible	Gerente

Personal	Veterinarios, auxiliares, recepcionistas, regente de farmacia, contadora	Tangible (talento humano)	Gerente
Intangibles	Marca, reputación, reseñas en línea y confianza de los clientes	Intangible	Gerente

Nota. Organización ficticia creada con fines académicos. Elaboración propia con base en las categorías de activos de MAGERIT v3 (Consejo Superior de Administración Electrónica, 2012).

¿Cómo debe ser la clasificación de la organización?

La clasificación de la información indica el nivel de protección que requiere cada activo según el daño que causaría su divulgación, alteración o pérdida (ISO, 2022a, control 5.12). Para una organización privada pequeña se propone una escala de cuatro niveles, compatible con la Guía 5 del Modelo de Seguridad y Privacidad de la Información (Ministerio de Tecnologías de la Información y las Comunicaciones [MinTIC], 2016) y con la Ley 1581 de 2012 sobre protección de datos personales:

- **Pública:** puede divulgarse sin daño (servicios, precios, horarios, publicaciones en redes).
- **Uso interno:** solo para los empleados; su divulgación causa un daño menor (turnos, protocolos, inventario de la tienda).
- **Confidencial:** datos personales de propietarios y empleados, historias clínicas, facturación. Su divulgación tiene consecuencias legales (Ley 1581 de 2012) y de reputación.
- **Restringida:** acceso solo de la gerencia o del responsable designado (credenciales, copias de seguridad, inventario de medicamentos de control, información contable y tributaria).

Cada activo debe tener un propietario que decide su clasificación, quién puede usarlo y cómo se etiqueta y se elimina. La clasificación se revisa cuando cambia el activo; por ejemplo, cuando un propietario pide que se borren sus datos o cuando se reemplaza un computador.

¿Qué metodologías o estándares se pueden usar para la valuación?

Existen varios marcos reconocidos para identificar y valorar activos dentro de un análisis de riesgos:

- **MAGERIT v3:** metodología pública española. Clasifica los activos por tipos y los valora en las dimensiones de disponibilidad, integridad, confidencialidad, autenticidad y trazabilidad, considerando las dependencias entre activos (Consejo Superior de Administración Electrónica, 2012).
- **NIST SP 800-30:** guía estadounidense de evaluación de riesgos en nueve pasos. El primero, la caracterización del sistema, incluye el inventario y la valoración de los activos (National Institute of Standards and Technology [NIST], 2012; Stoneburner et al., 2002).
- **ISO/IEC 27005:2022:** lineamientos para la gestión de riesgos de un sistema de gestión de seguridad de la información (SGSI) basado en ISO/IEC 27001. Admite enfoques basados en activos o en eventos (ISO, 2022b).
- **OCTAVE Allegro:** método del Software Engineering Institute centrado en los activos de información críticos, pensado para equipos pequeños (Caralli et al., 2007).
- **Guía 5 del MSPI (MinTIC):** referente colombiano para inventariar y clasificar activos de información en confidencialidad, integridad y disponibilidad (MinTIC, 2016).

Para Huellitas se escoge una valoración cualitativa en confidencialidad, integridad y disponibilidad (CID), con la escala de 1 (muy bajo) a 5 (muy alto) del componente formativo. Es sencilla de aplicar en una pyme y es compatible con NIST SP 800-30 y con la Guía 5 de MinTIC. El valor del activo es la suma de las tres dimensiones (máximo 15). Con esa suma, el activo se considera *crítico* de 13 a 15, *alto* de 10 a 12, *medio* de 7 a 9 y *bajo* hasta 6.

Tabla 2

Valuación de los principales activos de la Clínica Veterinaria Huellitas

Activo	C	I	D	Valor	Nivel	Clasificación
Historias clínicas	5	5	4	14	Crítico	Confidencial
Software de gestión veterinaria	5	5	5	15	Crítico	Restringida
Base de datos de propietarios	5	4	4	13	Crítico	Confidencial
Facturación y registros contables	4	5	4	13	Crítico	Restringida
Disco de copias de seguridad	5	5	3	13	Crítico	Restringida
Conexión a internet y router	3	4	5	12	Alto	Uso interno
Inventario de medicamentos de control	4	5	3	12	Alto	Restringida
Computadores de consultorio y recepción	4	4	4	12	Alto	Uso interno
Correo, WhatsApp Business y redes	4	4	4	12	Alto	Restringida
Equipo de rayos X y analizador de laboratorio	3	5	4	12	Alto	Uso interno
Información del personal	5	4	2	11	Alto	Confidencial
Marca y reputación	1	5	4	10	Alto	Pública
Página web y formulario de citas	2	4	3	9	Medio	Pública
Impresora multifuncional	3	2	2	7	Medio	Uso interno

Nota. C = confidencialidad, I = integridad, D = disponibilidad, en escala de 1 (muy bajo) a 5 (muy alto). Elaboración propia.

Los activos más críticos son los que guardan datos personales y clínicos: el software de gestión veterinaria, las historias clínicas, la base de datos de propietarios, la facturación y las copias de seguridad. Si se altera una historia clínica, un paciente puede recibir un tratamiento equivocado. Una fuga de datos de propietarios obligaría a responder ante la Superintendencia de Industria y Comercio, y si se cae el software o internet se detienen la agenda y la facturación. Por eso, las primeras medidas recomendadas son: usuarios individuales con verificación en dos pasos, perfiles por rol (veterinario, recepción, contabilidad), copias de seguridad cifradas con una copia fuera de la sede, wifi de invitados separada de la red interna y una política de tratamiento de datos firmada por los clientes.

Parte 2. Caso de estudio: proyecto ASEGURA

Descripción y alcance

La unidad del caso tramita expedientes con un sistema informático propio. Ese sistema está conectado a un archivo central que funciona como memoria histórica, y presta un servicio de administración electrónica: los ciudadanos tramitan por internet con su número de identificación y una contraseña, y un funcionario usa el mismo sistema para atender en persona (Servicio Nacional de Aprendizaje [SENA], s.f.). El alcance definido por el comité es el servicio de tramitación presencial y remota y la información que maneja (los expedientes), con los equipos y las redes que lo soportan. Quedan fuera los datos de identificación y autenticación de los usuarios, las áreas de trabajo, la sala de equipos, las personas y los servicios subsidiarios externos, que se tratan como "opacos".

Identificación y clasificación de los activos

La Tabla 3 amplía la clasificación de activos propuesta en el material de formación, separando los activos esenciales (información y servicios) de los activos que los soportan, y señalando los que el caso deja fuera del alcance.

Tabla 3

Identificación y clasificación de activos del caso de estudio

Categoría	Activos identificados	Clasificación de la información
Activos esenciales: información	Expedientes en trámite; expedientes cerrados del archivo central (memoria histórica)	Confidencial (contienen datos personales de los ciudadanos)
Activos esenciales: servicios	Tramitación presencial; tramitación electrónica vía web	Uso interno (el servicio es público, pero no su configuración)
Aplicaciones	Software de tramitación de expedientes; base de datos; portal web de administración electrónica; servicio de correo electrónico	Restringida (código y configuración)
Equipamiento	Servidor de aplicación y base de datos; computadores de escritorio del funcionario; equipos de red (enrutador, cortafuegos, conmutador); impresora; fotocopiadora	Uso interno
Comunicaciones	Red local (LAN); conexión a internet; enlace con el archivo central	Uso interno
Instalaciones	Edificio de la unidad. La sala de equipos queda fuera del alcance	—
Personal	Funcionario de atención (operador del software); ingeniero de sistemas. Las personas quedan fuera del alcance de esta fase	—
Fuera de alcance	Credenciales de los usuarios (número de identificación y contraseña); servicios subsidiarios externos	Restringida

Nota. Adaptado del caso de estudio del componente formativo "Ciberseguridad y seguridad de la información" (SENA, s.f.).

Valuación de los activos

Se aplican los criterios de la Tabla 3 del material de formación: confidencialidad (solo acceden los usuarios autorizados), integridad (solo los usuarios autorizados crean o modifican) y disponibilidad (los componentes están disponibles cuando se requieren), cada uno de 1 a 5. La Tabla 4 extiende a todas las categorías el ejemplo que el material solo desarrolla para el equipamiento.

Tabla 4

Valuación de los activos del caso de estudio

Categoría	Activo	C	I	D	Valor	Nivel
Esencial	Expedientes en trámite	5	5	4	14	Crítico
Esencial	Expedientes cerrados (archivo central)	5	5	3	13	Crítico
Esencial	Servicio de tramitación electrónica (web)	4	5	5	14	Crítico
Esencial	Servicio de tramitación presencial	4	5	4	13	Crítico
Aplicaciones	Software de tramitación y base de datos	5	5	5	15	Crítico
Aplicaciones	Portal web de administración electrónica	4	5	5	14	Crítico
Aplicaciones	Correo electrónico	4	3	3	10	Alto
Equipamiento	Servidor	5	5	5	15	Crítico
Equipamiento	Equipos de red (enrutador, cortafuegos)	4	5	5	14	Crítico
Equipamiento	Computadores de escritorio	4	4	3	11	Alto
Equipamiento	Impresora	3	1	1	5	Bajo
Equipamiento	Fotocopiadora	1	1	1	3	Bajo
Comunicaciones	Conexión a internet	3	4	5	12	Alto
Comunicaciones	Enlace con el archivo central	4	5	3	12	Alto
Comunicaciones	Red local (LAN)	3	4	4	11	Alto
Instalaciones	Edificio de la unidad	2	3	4	9	Medio
Personal	Funcionario de atención	3	4	4	11	Alto

Nota. Escala de 1 (muy bajo) a 5 (muy alto). Los valores de impresora, fotocopiadora, servidor y computadores coinciden con la Tabla 4 del material de formación (SENA, s.f.). Elaboración propia.

El resultado confirma la conclusión del material: el servidor que aloja el software de tramitación es el activo más crítico del equipamiento. Pero el análisis completo muestra que el riesgo se concentra en la cadena que sostiene el servicio web: expedientes, software y base de datos, servidor, equipos de red y conexión a internet. Una falla de integridad en cualquiera de ellos afecta trámites con efectos legales para los ciudadanos. Su indisponibilidad, además, sería visible para el público, que es justo el daño de imagen que preocupaba al promotor del proyecto. La impresora y la fotocopiadora tienen poco peso y pueden recibir controles básicos.

Estándar o marco de referencia que mejor se ajusta

El material desarrolla el ejemplo con NIST SP 800-30, cuyos dos primeros pasos (caracterización del sistema y valuación) sirven bien para un primer inventario. Sin embargo, el marco que mejor se ajusta al caso es **MAGERIT v3**, complementado con **ISO/IEC 27001 e ISO/IEC 27005**, por las siguientes razones:

- El caso es una unidad de la administración pública que presta un servicio de administración electrónica. MAGERIT fue creada justamente para que las administraciones públicas analicen los riesgos de esos servicios, y el propio caso (el proyecto ASEGURA y su comité de seguimiento) sigue la estructura de proyecto que propone MAGERIT (Consejo Superior de Administración Electrónica, 2012).
- MAGERIT distingue los activos esenciales (información y servicios) de los activos de soporte y modela sus dependencias. Esto permite propagar el valor del expediente hacia el servidor, la red y el portal, lo que explica por qué un equipo sin información propia resulta crítico.
- Valora además la autenticidad y la trazabilidad, dos dimensiones clave cuando los ciudadanos se identifican con su número de identificación y una contraseña, y cuando cada trámite debe dejar evidencia de quién lo hizo.
- ISO/IEC 27001 aporta el marco de gestión y los controles del Anexo A para el plan de tratamiento, e ISO/IEC 27005 da los lineamientos para el ciclo de evaluación de riesgos, que se repite cuando se lance el proyecto ASEGURA más detallado (ISO, 2022a, 2022b).

Los pasos de NIST SP 800-30 siguen siendo útiles como lista de verificación del proceso: identificación de amenazas y vulnerabilidades, análisis de controles, probabilidad, impacto, riesgo y recomendaciones. Así, la valuación hecha en este informe sirve de insumo para las siguientes actividades del programa: el mapa de amenazas y la matriz de riesgos.

Conclusiones

La valuación de activos convierte una intuición (“hay que proteger el sistema”) en prioridades concretas. Tanto en la clínica veterinaria como en la unidad del caso, los activos más críticos son los que contienen datos personales o sostienen un servicio que el cliente o el ciudadano usa directamente, y su protección exige a la vez controles técnicos, roles claros y cumplimiento de la ley de datos personales. Usar una escala común de confidencialidad, integridad y disponibilidad, dentro de un marco reconocido como MAGERIT o ISO/IEC 27005, hace que el análisis sea repetible y comparable en el tiempo.

Referencias

Caralli, R. A., Stevens, J. F., Young, L. R., & Wilson, W. R. (2007). *Introducing OCTAVE Allegro: Improving the information security risk assessment process* (CMU/SEI-2007-TR-012). Software Engineering Institute, Carnegie Mellon University.

Congreso de la República de Colombia. (2012, 17 de octubre). *Ley Estatutaria 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales*. Diario Oficial No. 48.587.

Consejo Superior de Administración Electrónica. (2012). *MAGERIT – versión 3.0. Metodología de análisis y gestión de riesgos de los sistemas de información. Libro I: Método*. Ministerio de Hacienda y Administraciones Públicas.

International Organization for Standardization. (2022a). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC Standard No. 27001:2022).

International Organization for Standardization. (2022b). *Information security, cybersecurity and privacy protection — Guidance on managing information security risks* (ISO/IEC Standard No. 27005:2022).

Ministerio de Tecnologías de la Información y las Comunicaciones. (2016). *Guía para la gestión y clasificación de activos de información* (Guía No. 5, Modelo de Seguridad y Privacidad de la Información). MinTIC.

National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30, Rev. 1). https://doi.org/10.6028/NIST.SP.800-30r1

Servicio Nacional de Aprendizaje. (s.f.). *Ciberseguridad y seguridad de la información* [Componente formativo y caso de estudio]. Programa Apropiación de los conceptos en ciberseguridad. SENA.

Stoneburner, G., Goguen, A., & Feringa, A. (2002). *Risk management guide for information technology systems* (NIST Special Publication 800-30). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-30